

- c. Restricts account access and limits privileges and permissions.
 - d. Implements password management tools or activities.
 - e. Employs an appropriate level of encryption according to the entity's data classification policy.
 - f. Configures and reviews audit logs.
 - g. Regularly monitors database activity logs.
 - h. Independently monitors DBA and privileged account activities.
 - i. Classifies data maintained within the database.
 - j. Restricts and monitors data extraction.
 - k. Implements and adheres to patch management processes.
 - l. Implements OS controls.
 - m. Monitors OS-level privileged account activities.
 - n. Manages application-level access.
8. Determine whether management considers design, placement, and effective security controls for non-production environments (e.g., development, test, and quality assurance). Consider the following:
- a. Independence of non-production environments from production environments to maintain data integrity and resilience.
 - b. Use of simulated synthetic data in non-production environments, when possible.
 - c. Controls to prevent testing in production environments to maintain confidentiality, integrity, and availability of data.
 - d. Use of masked or sanitized test data in non-production environments when production is used; if this is not feasible, approvals to use non-sanitized data with implementation of the same level of controls in non-production environments as in production environments.
9. Determine whether management appropriately considers the uses and risks of data analytics and performs the following:
- a. Limits access to analytics tools and related outputs.
 - b. Incorporates confidentiality, integrity, and availability when designing or selecting analytics tools.
 - c. Inventories the data sources, assesses the information type according to the entity's data classification policy, and appropriately secures those sources.
 - d. Develops design requirements and parameters for analytics.
 - e. Obtains sufficient knowledge for management and personnel to interpret dashboards and reports.
 - f. Considers the following when implementing and using data analytics:
 - Documentation of the data types maintained, data owners and users, and purposes of reports.
 - Determination of stakeholders' usage needs.
 - Determination of potential opt-in considerations, based on information type, in analytics reports.
 - Determination of disclosure requirements in the event of an incident.

- Implementation of access controls and activity monitoring over analytics tools and reports.
- Definition of processes to remove or destroy data when no longer used in the data analytics tools.
- Identification of data subject to applicable laws and regulations or other relevant industry standards.
- Identification of data analytics processes used to enable compliance with applicable laws and regulations.
- *This examination procedure may be coordinated with related examination procedures in the “[Information Security](#)” booklet. If the entity uses big data, implementation of appropriate security policies, standards, and procedures, along with data access and security controls in accordance with the entity’s data classification policy.*

Objective 4: Management implements appropriate ITAM processes to track, manage, and report on the entity’s information and technology assets. (III.B, “[IT Asset Management](#)”)

The examination procedures in this objective may be coordinated with related examination procedures in the “[Information Security](#)” booklet.

1. Determine whether management has a comprehensive inventory of its electronic (or digital) and physical information assets, in accordance with the Information Security Standards. Evaluate whether management specifically identifies its information assets, determines the appropriate classification of those assets, and protects them according to the entity’s data classification process.
2. Determine whether management implemented policies, standards, and procedures to govern all aspects of ITAM, including information and technology assets. Assess whether those processes include the following:
 - a. Identifying the technology assets the entity possesses and manages.
 - b. Determining each asset’s status (e.g., active or inactive).
 - c. Specifying the life cycle phase of those assets.
 - d. Regularly reviewing and validating the accuracy of the inventories.
 - e. Identifying personally owned technology assets that are allowed to connect to the entity’s network.
3. Determine whether management uses appropriate inventory mechanisms to effectively document, track, and oversee the entity’s information and technology assets, including its hardware and software. As part of the technology asset inventory, determine whether management considers IT assets that do not fall into traditional hardware or software inventories. Evaluate whether management has a process to periodically review and update the inventories. Assess the adequacy of management’s technology asset inventory process for the following:
 - a. Hardware inventory process that does the following:

- Identifies the entity's hardware assets.
 - Identifies equipment owned and managed by third parties on the entity's behalf.
 - Includes entity-owned and entity-managed virtual infrastructures.
 - Assigns a unique identifier for hardware assets.
 - Contains information about the network and telecommunications equipment.
 - Contains appropriate information on each piece of hardware.
 - b. Software inventory process that does the following:
 - Provides detailed information on software used in the entity's IT environment.
 - Contains appropriate information on the entity's software.
4. Assess whether each IT asset is captured in the entity's ITAM inventory, tracked throughout its operational life, and prepared for physical removal at the end of its useful life. Determine whether management implemented policies, standards, and procedures to identify assets and their EOL time frames, to track assets' EOLs, and to replace or upgrade the asset. Determine the effectiveness of EOL management through the following:
- a. Addresses EOL in contract provisions with its third-party service providers.
 - b. Adds assets to the inventories and tracks changes made to assets.
 - c. Conducts risk assessments to determine assets' EOLs.
 - d. Reviews EOL time frames for existing assets to determine accuracy and relevance.
 - e. Develops replacement plans for assets nearing obsolescence.
 - f. Establishes procedures for the secure destruction or data wiping of hardware and software.
 - g. Considers the following when reviewing new technology assets:
 - Incorporates EOL considerations in strategic planning.
 - Plans for obsolescence during initial project stages (e.g., during requests for proposals or proofs of concept).
 - Registers and tracks assets in the inventories and includes EOL information.
 - Develops plans for maintaining IT assets beyond EOL, if necessary.
5. Determine whether management understands and communicates the risks of shadow IT to entity personnel. Additionally, determine whether internal audit evaluates management's processes to monitor, identify, and remove unapproved devices, software, or services. Assess whether management performs the following:
- a. Establishes IT governance practices and security controls for shadow IT, including policies, standards, and procedures.
 - b. Includes shadow IT in security awareness training.
 - c. Considers the use of IT detection tools to monitor for and identify shadow IT.
 - d. Employs appropriate data protection and data loss prevention tools.
 - e. Considers appropriate methods to address shadow IT, including:
 - Identifying security risks associated with shadow IT in use and determining whether there is malicious intent.
 - Identifying the reason for its use.
 - Determining clients or processes supported by shadow IT.

- Verifying interconnectivity between shadow IT and third-party service providers or existing software integration.
 - Determining appropriate disposition of shadow IT.
 - Reviewing policies, processes, and tools to understand any gaps that may allow shadow IT to occur.
- f. Has processes to monitor, identify, and remove shadow IT that can be evaluated by internal audit.

Objective 5: Management understands the documentation maintained to represent the entity's IT and business environment. (III.C, ["IT and Business Environment Representations"](#))

1. Determine whether management documents and maintains accurate representations (e.g., network diagrams, data flow diagrams, business process flow diagrams, and business process narratives) of the current IT and business environments and employs processes to update the representations.
2. With the representations, assess whether management does the following:
 - a. Coordinates the development of representations among stakeholders.
 - b. Aligns diagrams and narratives with each other and across the entity's lines of business.
 - c. Periodically reviews documented diagrams and narratives to confirm the accuracy of the representations of the IT and business environment.
 - d. Provides for the resilience of this documentation by maintaining current and accurate backups.
 - e. Implements appropriate access and editing privileges to the representations.

Objective 6: Management fosters effective management of change across the AIO functions. (III.D, ["Managing Change in AIO"](#))

The examination procedures in this objective may be coordinated with related examination procedures in the ["Development and Acquisition"](#) booklet.

1. Determine whether the IT environment and its products and services, whether internally or externally provided, are adaptable to change, and stakeholders from across the entity have input into the change process.
2. Depending on the complexity of the change, determine the adequacy of the processes to manage the change. Verify that changes to any IT system or service are supported by an orderly, adaptable, documented, and measurable process.
 - a. If the entity implements more complex types of changes (e.g., core conversions, migrations to cloud-based environments, or implementing a system to support a new product), assess whether formal planning and management oversight processes are in place and adequate.

- b. If the entity implements less complex, but planned changes (e.g., implementation of patches), assess the appropriateness of the change process.
3. Determine whether the entity's policies, standards, and procedures address change management, including each step of the change process. Assess whether the process includes the following:
 - a. Categorization of changes by severity.
 - b. Specification of corresponding approval processes.
 - c. Identification of responsible staff, applicable stakeholder working groups, or entity committees.
 - d. Preservation of the IT environment's confidentiality, integrity, and availability.
 - e. Identification of metrics to track the efficiency and success of the change.
 - f. Implementation of changes with the goal of preserving confidentiality, integrity, and availability.
 - g. Incorporation of appropriate segregation of duties and monitoring throughout the change management process.
4. Review and evaluate the entity's change management process to implement changes that preserve systems' security and are based on the change type (e.g., planned, routine, and emergency). Determine whether management follows pre-defined processes, such as the following:
 - a. Request that includes the reasons for the change and details of the change.
 - b. Review of requests to determine viability, business practicality, and prioritization.
 - c. Approval through the appropriate documented hierarchy commensurate with the scope, cost, urgency, and overall risk.
 - d. Design and build, including formal processes to preserve integrity throughout the development life cycle and ensure adequate controls.
 - e. Testing, which documents that the change performs as intended, identifies flaws, and verifies that the change integrates with other systems.
 - f. Implementation that includes a formal process to deploy the change.
 - g. Verification and closure, including a post-implementation review and processes to document the change's closure.
5. When reviewing change management, evaluate the following transition processes:
 - a. Management implements a process to transition system changes from a strategic change management process to day-to-day operations.
 - b. Knowledge is adequately transferred to personnel who will be responsible for operating the systems and processes.
 - c. Change management processes allow for the transition of responsibilities and knowledge and are part of the overall system development life cycle.

Objective 7: Management maintains effective oversight of the entity's third-party service providers responsible for activities related to AIO functions. (III.E, "Oversight of Third-Party Service Providers")

1. Determine whether management identifies internal and external roles and responsibilities for AIO activities and implements processes to oversee those activities performed by third-party service providers. Assess whether management appropriately assigned and defined the responsibility and oversight of those activities.
2. Verify whether management identifies and addresses all risks according to contracts and other agreements (e.g., SLAs).
3. With respect to data destruction processes at the third-party service provider, determine the following:
 - a. Management is aware of the data destruction processes maintained by the entity's third-party services providers, including cloud service providers.
 - b. SLAs outline adequate third-party service providers' data destruction measures.
4. Determine whether management reviews independent audit or other assurance reports demonstrating the third-party service provider's ability to meet the entity's AIO needs.
5. Verify that management reports to the board on the effectiveness of any AIO activities performed by third-party service providers. Assess whether the reporting included any issues uncovered through the entity's third-party risk management processes.

Objective 8: Management adequately considers and implements resilience as part of the entity's risk mitigation strategy for AIO. (III.F, "Resilience")

1. Evaluate whether management integrates the entity's AIO functions into the entity's BCM program to mitigate threats, respond to and recover from disruptions, and incorporate lessons learned to strengthen the entity's resilience.
2. Determine whether management designs, implements, and operates its IT systems and processes to provide resilience for critical business activities. Assess whether management does the following:
 - a. Determines its reliance on people, processes, and technology, including third-party service providers, to assist in its assessment of risk.
 - b. Ensures the entity's business strategy and reliance on business functions drive the design for the entity's resilience.
 - c. Designs systems and software with resilience and information and cybersecurity at the beginning of the architecture process.
 - d. Uses infrastructure that supports varying levels of resilience depending on the criticality of the systems and software to ongoing business operations.

- e. Implements infrastructure to allow for secure remote administration and maintenance, for situations where personnel are unable to perform operations on site.
- f. Addresses resilience in operations to prevent data loss, protect sensitive customer information from unauthorized disclosure or manipulation, minimize disruption to service delivery, and prevent the loss of situational awareness of the entity's operations. Evaluate whether this operational resilience includes having:
 - Operational controls.
 - Operational processes (e.g., vulnerability and patch management).
 - Service delivery and support processes (e.g., resilience in supply chain).
 - Ongoing monitoring and evaluation capabilities (e.g., monitoring for indicators of an APT).
- g. Avoids making assumptions on the resilience of the entity's systems simply because they are operating in the cloud.
- h. Identifies assets, applications, and services located in the cloud, if operating in the cloud.
- i. Verifies that resilience is covered in contracts with cloud service providers.

Objective 9: Management has appropriate AIO processes for managing remote access.
(III.G, "[Remote Access](#)")

1. Evaluate whether management considers the implications of remote access in AIO and does the following:
 - a. Designs for remote access capabilities, including:
 - Plans for the methods and access points to maintain security and control access to entity resources.
 - Considers appropriate methods (e.g., tunneling, web portals, direct application access, and remote desktop access).
 - Considers protection of communications and security needs (e.g., encryption, authentication, access restrictions, application security, and activity monitoring).
 - b. Uses remote access technologies that can be protected.
 - c. Employs effective risk mitigation for remote access, including:
 - Remote access policy that includes tiered levels of remote access and risk-based security controls.
 - IAM based on job type and access and appropriate authentication techniques.
 - Encryption technologies to protect communications.
 - Securely configured and patched remote access servers.
 - Secure entity-owned telework client devices.
 - Controls on the use of personally owned devices used to remotely access entity resources.

Objective 10: Management incorporates AIO considerations into the decision to use and use of personally owned devices. (III.H, “[Personally Owned Devices](#)”)

1. Determine whether management adequately considered AIO in the decision to allow the use of personally owned devices. Specifically, evaluate the effectiveness of the following:
 - a. Due diligence to determine types of devices that can be used.
 - b. Consideration of the architecture of the entity’s IT systems, such as where and how the devices will access the bank’s network.
 - c. Determination of additional infrastructure needed to support the secure use of personally owned devices.
 - d. Controls needed to adequately safeguard the network.
 - e. Use of technical policy enforcement to manage or restrict devices used.

Objective 11: Management incorporates AIO considerations into the design, implementation, and use of file exchange. (III.I, “[File Exchange](#)”)

1. Determine whether management considers risks related to exchange files and implements effective mitigation, such as the following:
 - a. Identification of user needs for exchanging files, both internally and externally.
 - b. Design of client server architecture to provide for confidentiality, integrity, availability, and resilience.
 - c. Identification of the infrastructure, including the appropriate systems and software, necessary to support file exchange activities.
 - d. Inclusion of appropriate infrastructure to support monitoring of the entity’s file exchange activities.
 - e. Implementation of appropriate operational controls, such as:
 - Monitoring for authorized file exchange.
 - Use of detection controls.
 - Use of only a trusted provider for third-party file exchange and storage solutions.
 - Consideration of solutions that provide visibility into cloud applications.
 - Definition of appropriate policies, standards, and procedures for file exchange activities.
 - Provision of training to employees on approved solutions.

Objective 12: Management designs, applies, and aligns its IT architecture to meet the strategic and business objectives of the enterprise. (IV, “[Architecture](#)”)

1. Determine whether management established enterprise-wide architecture principles that balance the mitigation of risks to various stakeholders and align with the entity’s strategic goals and business objectives; meet the entity’s needs for confidentiality, integrity, and availability; and adhere to the entity’s policies, standards, and procedures. Determine whether the architecture design involves the following:

- a. Consideration of the entity's architecture requirements for its existing technology and any planned changes.
 - b. Understanding by business units of their portion of the design.
 - c. Alignment with management's defined mission and any strategic initiatives for architecture.
 - d. Identification of the entity's IT assets, external constraints, industry IT architecture trends, and the entity's needs for the desired future state.
2. Determine whether management has policies, standards, and procedures to govern the entity's architecture design process and whether the design process addresses the following:
 - a. Definition of responsibilities and decision-making.
 - b. Identification of functional requirements.
 - c. Assessment of alignment with the entity's IT and strategic plans.
 - d. Evaluation of the inventory of current IT assets and the purpose of those assets.
 - e. Performance of a cost-benefit analysis of the architecture plan or project.
 - f. Acquisition of approvals for the initiative.
 - g. Implementation and maintenance of the architecture.
 - h. Resolution of disputes or architectural issues.
3. Evaluate the adequacy of the entity's documented and approved architecture plan. Consider whether management considers the following in relationship to the plan:
 - a. Alignment with the entity's strategic plan and support for the business and strategic objectives of the entity.
 - b. Development of policies, standards, and procedures to govern architecture initiatives and changes to the architecture plan.
 - c. Inclusion of processes for obtaining approvals, making changes to the plan, and reporting, as appropriate.
 - d. Alignment of the formality of the architecture plan and processes with number and complexity of the architecture initiatives.
 - e. For larger or more complex architecture changes, maintenance of a project management process that includes the following:
 - Planning.
 - Execution.
 - Closeout.
4. With respect to design objectives, determine whether management does the following:
 - a. Uses defined terminology.
 - b. Evaluates its needs and considers:
 - Collaboration between IT and business units.
 - Prioritization of investments.
 - Comparison of existing architecture with anticipated future changes.
 - Establishment of processes to evaluate and procure technology.
 - Storage, backup, and capacity needs to accommodate the entity's strategic plans.

- Type of applications the architecture will support.
 - c. Includes the following aspects in its architecture design:
 - Performance and reliability.
 - Integrity.
 - Availability and resilience.
 - Scalability.
 - Flexibility.
 - Security and privacy.
 - Interoperability and integration.
 - Ability to integrate and align with one or more third-party service providers.
 - Testing internally and with third-party service providers, as appropriate.
 - Auditability.
 - Advancements in technology.
 - d. Includes considerations for avoiding the potential for shadow IT and the capability to monitor and alert for its use.
 - e. Considers how evolving technologies (e.g., cloud, IoT, and AI/ML) can affect its design.
 - f. Plans for obsolescence, EOL, and decommissioning of systems.
- 5. Evaluate whether management has a process to determine appropriate deployment environments (e.g., in-house or serviced, virtualization and cloud, or hybrid) as part of the design process. Determine whether the process includes the following considerations:
 - a. Identification of risks and benefits of each type of deployment environment.
 - b. Use of physical versus virtual components in the design.
 - c. Type of virtualization solution and design risks associated with the following elements:
 - VMs and the design of secure virtual infrastructures to provide the ability to oversee the interconnectivity and segmentation of VMs.
 - Hypervisors and the design of where the hypervisors sit and the connectivity between hypervisors and VMs.
 - Containers, including the design for storing data outside of the container and implementation of vulnerability management processes, segmentation, and the ability to monitor containers.
 - Microservices, including a design process that allows for the use of microservices as an integrated component to overall IT operations and the ability to address the risks of security, reliability, and latency in the entity's development process.
 - d. Placement and selection of storage, design of network topology, availability of bandwidth, and need for management reporting systems, as well as implementation of monitoring tools.
- 6. In larger or more complex entities, determine whether management considered using EA to align its architecture with the entity's strategic plans and business functions. Describe management's implementation of EA and use of architecture frameworks, if appropriate. Regardless of entity size, determine whether management incorporated the following:
 - a. Evaluation of approaches to implement and build security and resilience throughout its architecture.